Faso Cikan : note de sécurité

Ce que Faso Cikan protège, contre qui, et ce qu'il ne protège pas. Nous avons préféré écrire les limites noir sur blanc plutôt que de laisser croire que tout est couvert.

Menaces prises en compte et protections

Menace	Ce qui est en place
L'hébergeur ou un administrateur système lit les messages	Chiffrement de bout en bout (Olm et Megolm), fait uniquement sur les appareils. Le serveur ne stocke que du texte chiffré.
Un client mal configuré envoie en clair	Le module serveur faso_cikan refuse tout message non chiffré (erreur 403). Les salons sont chiffrés par défaut.
Une personne extérieure à l'administration	Inscription fermée, fédération coupée, connexion possible seulement par Keycloak. Un matricule non enrôlé est rejeté.
Vol d'un mot de passe	Un code à usage unique est demandé à chaque connexion, et un code ne sert qu'une fois.
Essais de mots de passe en série	Keycloak verrouille le compte, une minute dès deux échecs rapprochés, puis de plus en plus longtemps.
Un compte existe mais n'a pas d'autorisation	Synapse exige le rôle « agent » dans le jeton d'identité. Sans lui, la connexion est refusée.
Agent muté, radié, téléphone perdu	Révocation : compte Keycloak désactivé, sessions fermées, compte Matrix désactivé (jetons et appareils supprimés), sortie de tous les salons. Chaque révocation est inscrite dans un journal d'audit.
Un document classifié est transféré	L'option « Transférer » est retirée du client, la boîte de transfert est bloquée, la modification est interdite.
Un message confidentiel qui traîne	Le serveur l'efface à l'échéance, et le contenu chiffré disparaît de la base une minute plus tard.
Prise de contrôle par l'API d'administration	Le proxy ne la publie pas. Seule la console y accède, par le réseau interne.
Usurpation de nom dans une conversation	Le nom affiché vient de l'annuaire Keycloak. L'agent ne peut pas le modifier.

Ce que le serveur voit malgré tout

Le chiffrement protège le contenu, pas les informations dont le serveur a besoin pour acheminer les messages. Il connaît l'expéditeur, le salon et l'heure de chaque message, la liste des membres de chaque salon et l'adresse IP de connexion. Il voit aussi la taille des pièces jointes, qui sont ellesmêmes chiffrées. Pour un message classifié, il voit en plus le niveau et le délai d'expiration : l'étiquette voyage en clair à côté du texte chiffré, sans quoi il ne pourrait pas effacer le message à l'échéance.

Pour limiter ce qu'il apprend, nous avons coupé la présence en ligne (pas de « vu à »), réduit la conservation des adresses IP à un jour, désactivé les aperçus de liens pour que le serveur n'aille jamais chercher une page à la place d'un agent, fixé la purge des messages supprimés à une minute et limité les médias locaux à un an. La fédération étant coupée, aucun autre serveur ne reçoit ces informations.

Limites connues

- **Un agent révoqué garde ce qu'il a déjà reçu.** La révocation lui coupe l'accès au serveur, mais elle ne peut pas vider la mémoire de son appareil. Un appareil perdu doit aussi être traité par la gestion de flotte du ministère.
- **La classification est appliquée par le client.** Un agent qui utilise un client Matrix modifié, ou qui recopie le texte à la main, peut faire circuler un contenu confidentiel. Le serveur ne lit pas les messages : il ne peut pas savoir qu'un nouveau message reprend un ancien. Faso Cikan évite les erreurs et les gestes trop faciles, pas la malveillance d'un agent habilité.
- **Les captures d'écran ne sont pas bloquées**, parce qu'un navigateur ne le permet pas. Ce blocage est prévu dans une future application mobile.
- **L'effacement à l'échéance passe par la rédaction Matrix.** Un appareil hors ligne garde le message jusqu'à sa reconnexion.
- **Deux étiquettes peuvent diverger** si un client malveillant écrit l'étiquette en clair et l'étiquette chiffrée différemment. Le serveur se fie à la première pour l'expiration, le client à la seconde pour l'affichage.
- **Le code à usage unique ne protège pas d'un hameçonnage en temps réel.** Une clé de sécurité matérielle (WebAuthn) le ferait. Keycloak sait la gérer, et nous la recommandons pour les autorités.
- **Un administrateur Keycloak peut créer un compte.** C'est à l'organisation d'encadrer ce pouvoir : comptes nominatifs, journal Keycloak, séparation entre exploitation et autorité.
- **Le code n'a pas été audité** par un tiers. Nous recommandons un audit du patch client et du module serveur avant tout usage réel.

Avant une vraie mise en service

Mettre un vrai domaine (Caddy obtient alors des certificats publics), supprimer le dossier `demo/` et les comptes de démonstration, limiter l'accès à l'administration de Keycloak au réseau d'exploitation et sauvegarder les volumes PostgreSQL et Synapse (qui contient la clé de signature), chiffrés et hors site.